

SOC INVESTIGATION REPORTS

Phishing Email Investigation

Prepared by: Rushabh Shah

Investigation Report — Phishing Email

Investigation Type: Phishing Email / Email Security Investigation

Primary Focus: Email analysis, IOC identification, URL analysis, threat validation

Alert Source: SIEM / Email Security Alert

Typical Alert: Suspected Phishing Email / Malicious URL / Suspicious Email Indicator

Severity: Medium to High depending on user interaction, IOC reputation, and business impact

1. Incident Summary

A suspected phishing email alert was received for a user mailbox. The alert indicated that the email contained characteristics requiring investigation. The investigation focused on the sender, email headers, URLs, available IOCs, and user interaction to determine whether the email was malicious.

2. Tools Used

- SIEM — Used to review the alert, correlate related security events, and check whether the sender, URL, or user generated additional security events.
- Email Security / Mail Logs — Used to review sender details, recipients, delivery information, and message activity.
- Email Header Analyzer — Used to inspect header fields, mail path, originating information, and authentication results.
- VirusTotal — Used to check the reputation of suspicious URLs, domains, IP addresses, and file hashes when available.
- WHOIS / Domain Information — Used to review domain registration and basic domain information when the domain appeared suspicious.
- URL Scanner / Sandbox — Used when safe and authorized to analyze a suspicious URL without directly interacting with it from the corporate endpoint.

3. Alert Received

The investigation started from a security alert identifying a suspected phishing email. The alert provided the available email details, such as sender, recipient, subject, timestamp, and one or more suspicious indicators. The alert was reviewed first to understand why it had been generated and to determine the initial severity.

4. Investigation Steps

1. Review the SIEM/email security alert. Confirm the alert timestamp, affected user, sender, recipient, subject, and reason for detection.
2. Check the sender information. Review the sender address and domain for impersonation, spelling differences, suspicious domains, or inconsistencies.

3. Analyze the email headers. Review fields such as From, Reply-To, Return-Path, Received, SPF, DKIM, and DMARC results to understand the message path and authentication status.
4. Extract the indicators. Identify suspicious domains, URLs, IP addresses, attachment names, and file hashes if present.
5. Check IOC reputation. Search suspicious domains, URLs, IPs, and hashes using approved threat-intelligence sources such as VirusTotal.
6. Analyze suspicious URLs safely. Do not open a suspicious link directly from the corporate endpoint. Use an approved URL analysis or sandboxing solution when required.
7. Check user activity. Review SIEM or endpoint logs to determine whether the user clicked the URL, downloaded an attachment, authenticated to a suspicious destination, or generated related security events.
8. Correlate related events. Search the SIEM around the email timestamp for additional authentication events, endpoint alerts, network connections, or other indicators associated with the user or IOC.
9. Determine severity. Consider IOC reputation, user interaction, affected account, asset criticality, evidence of compromise, and potential business impact.
10. Document and escalate. Record the evidence, timeline, IOCs, findings, and recommended action. Escalate confirmed or high-confidence malicious activity according to the SOC process.

5. How the Phishing Email Was Identified

- The initial alert identified the email as suspicious based on email-security detection or SIEM correlation.
- Sender and domain information were reviewed for impersonation or suspicious characteristics.
- Header authentication results and message-routing information were checked.
- URLs and other IOCs were extracted and checked against threat-intelligence sources.
- User and endpoint activity was reviewed to determine whether the email resulted in any suspicious behavior.

6. Key Findings

- The email contained indicators requiring security investigation rather than being treated as normal business communication.
- Sender information, header data, and embedded URLs were reviewed as part of the investigation.
- Relevant IOCs were identified and correlated with available security telemetry.
- The investigation determined whether there was evidence of user interaction or additional suspicious activity.

7. Response / Action Taken

- Documented the investigation findings and relevant IOCs.
- Escalated the incident when malicious or high-confidence indicators were identified.
- Recommended removal/quarantine of the phishing email and blocking confirmed malicious indicators where applicable.
- Recommended additional endpoint and account monitoring when user interaction or possible compromise was identified.

8. Investigation Outcome

The investigation provided a complete view of the suspicious email by correlating email details, headers, IOCs, threat intelligence, and user activity. The final classification and escalation were based on the evidence collected during the investigation.